TP5 - Analyse de risques de la chaîne Git

Auteur : Bilal5464 (AbdelGhani) | Dépôt : bloc3-cyber | Contexte : DSI MyCallCenter

Étape 1 - Recenser les biens supports

Analyse de l'environnement réel et des composants de la chaîne Git utilisés depuis le début de l'année.

Bien support	Ce qu'il porte	Qui le contrôle
Poste de travail local (.git/)	Code source, historique, configurations locales, fichiers de travail	Étudiant (Bilal5464)
Dépôt distant sur GitHub	Copie officielle du dépôt, historique public, branches	GitHub / Étudiant
Compte GitHub	Identifiant, e-mail, habilitations d'accès	Étudiant / GitHub
Credential Manager	Jetons d'accès (Tokens) / mots de passe en cache	OS de la machine locale
Historique des commits	Noms et e-mails des contributeurs (Sacha Vidal, T. Robert, etc.)	Équipe / Historique Git

Étape 2 - Identifier les vulnérabilités constatées

2.1 Audit local : Aucun secret clair dans l'historique (`git log -G`). Présence d'un `.gitignore` mais absence de la règle pour le fichier `.env`. Présence de fichiers de données personnelles suivis (`data/participants-atelier.csv`).
2.2 Audit de la forge : Dépôt configuré en mode **Public** (V1). Collaborateurs actifs (V2). Double authentification (2FA) non activée (V3). Branche `main` non protégée (V4). Aucun fork externe (V5).

Étape 3 - Analyser les scénarios de menace

Évaluation des scénarios de référence en fonction des vulnérabilités constatées sur le dépôt et la forge.

Réf.	Bien visé	Vrais.	Justification (basée sur l'étape 2)	Gravité & DICP
R1	Poste / Dépôt	2	Le fichier `.gitignore` ne couvre pas `.env`, risque de commit par inadvertance.	G:3 | C
R2	Compte GitHub	3	La double authentification (2FA) n'est pas activée sur le profil GitHub.	G:4 | I, D
R3	Dépôt GitHub	2	Présence de collaborateurs historiques dont les accès n'ont pas été révoqués.	G:3 | I
R4	Dépôt distant	3	La branche `main` n'est pas protégée, un `git push --force` est possible.	G:3 | I, D
R5	Historique Git	4	Le dépôt est **Public** et contient des données personnelles suivies (`participants-atelier.csv`).	G:4 | C

Étape 4 - Cartographier et prioriser

a) Risques en haut à droite (Priorités absolues) : Le risque **R5** (données personnelles sur dépôt public) et le risque **R2** (compte sans 2FA) se positionnent en criticité maximale du fait de l'exposition publique immédiate.

b) Comparaison de criticité : R2 et R4 peuvent afficher une criticité similaire mais exigent des réponses totalement opposées : R2 relève de la sécurité du compte personnel (activation de la 2FA), tandis que R4 relève de la gouvernance du dépôt distant (règles de protection de branche).

Étape 5 - Traiter et rendre

Plan de traitement des risques identifiés et mesures correctives associées.

Réf.	Option	Mesure concrète et vérifiable
R1	Réduire	Ajouter explicitement la ligne `.env` dans le fichier `.gitignore` local et le pousser. Vérification : `git status` ignore le fichier.
R2	Réduire	Activer la double authentification via *Settings* > *Password and authentication*. Vérification : La page affiche "2FA enabled".
R3	Réduire	Supprimer les anciens accès dans *Settings* > *Collaborators*. Vérification : Liste des collaborateurs nettoyée.
R4	Réduire	Protéger la branche `main` via *Settings* > *Branches* > *Add classic branch protection rule* (cocher "Require pull request").
R5	Éviter / Réduire	Retirer les fichiers de données personnelles du suivi Git ou basculer le dépôt en mode **Private**. Vérification : Dépôt inaccessible au public.

Application immédiate

Mise en place de la mesure prioritaire sur le dépôt `bloc3-cyber` : activation de la protection de branche et du `.gitignore` enrichi pour éliminer l'exposition des données sensibles.

Note au DPO (synthèse)

> Objet : Note d'analyse de risques de la chaîne Git (Dépôt bloc3-cyber) 1. Biens supports : Poste local, compte GitHub, historique public et fichiers de données personnelles portés par le SIO. 2. Vulnérabilités majeures : Dépôt public contenant des fichiers CSV nominatifs, absence de 2FA sur le compte, branche principale non protégée contre l'écrasement. 3. Priorités : Traitement prioritaire de l'exposition des données personnelles (R5) et du compromis d'authentification (R2). 4. Traitement appliqué : Durcissement des paramètres de forge (activation de la sécurité et nettoyage des accès). 5. Risque résiduel : Acceptation du risque résiduel inhérent aux contributions publiques contrôlées pour les besoins pédagogiques du module.